

Ringln — Comprehensive Audit

Generated 2026-05-17 · 5 agents + supervisor · Covers HomeScreen, Messages, Calls, Profile, Settings, SearchScreen, OTA, Security, and Social-media comparison

⚠️ Executive Summary — 9 CRITICAL issues need immediate attention

The app's features and UX are solid. But there are **9 RED criticals** spanning security and data integrity that should be fixed before any paid marketing. Top 3: (1) **WalletScreen lets any user self-credit unlimited coins** via browser console. (2) **Agora token endpoint + call_invites RLS** together allow anonymous strangers to join active call channels and eavesdrop on private conversations. (3) **ProfileScreen saveEditProfile** overwrites your bio JSON every time you edit name/about — silently wipes cover_url, notification prefs, sound prefs, expert application.

9

● CRITICAL

21

● HIGH

47

● MEDIUM

15

● LOW

CONTENTS

- Top 5 fixes to ship first
- All critical issues
- HomeScreen + Feed
- Moments
- Messages + Chat
- Calls + Agora
- Profile + Settings
- SearchScreen
- OTA + Update flow
- Security findings
- Social-media comparison
- Recommendations
- What works well

★ Top 5 fixes to ship first

1. **Lock down the coin economy** — Move all coin grants/debits behind a server-side SECURITY DEFINER RPC tied to a real Stripe/Razorpay webhook. Right now anyone can `sb.from('profiles').update({coins:999999})` from devtools. (~1 day)
2. **Authenticate the Agora token + send-call-push endpoints** — Both API routes mint tokens / fire pushes with no auth check. Add Supabase JWT verification + validate against the `call_invites` row. Also revert `AGORA_RLS_LOOSEN.sql`. (~half day)
3. **Stop wiping the profile bio** — In `ProfileScreen.js` fix `saveEditProfile` (L431), `Save Profile Info` (L978), and `Expert App submit` (L1805) to re-fetch + merge before writing the bio JSON. Currently every edit silently wipes `notif_prefs`, `sound_prefs`, `cover_url`. (~1 hour)
4. **Wire Profile's onViewUser / onSwitchTab props** — `ProfileScreen` body uses `props.onViewUser` + `props.onSwitchTab` but only destructures `{session, supabase, onOpenWallet}`. Tapping a liker name or "View My Moment" throws `ReferenceError`. (~5 minutes)
5. **Public post / expert pages + invite-friend loop** — Without `/post/:id` and `/expert/:id` SSR routes, every share link returns the SPA shell and breaks the share-back loop. This is the biggest growth blocker. (~2 days)

● All 9 critical issues

AREA	LOCATION	DESCRIPTION	FIX
Security	python-service/.env:4	Committed admin API key ringin-admin-secret-2026 grants full access to analytics endpoints. Public repo.	<i>git rm --cached, rotate key, add to .gitignore.</i>
Security	api/agora-token.js	No auth. Any anonymous client can mint a PUBLISHER token for any channel + join active calls + inject audio.	<i>Verify Supabase JWT + check caller is participant on call_invites row.</i>
Security	AGORA_RLS_LOOSEN.sql	call_invites RLS is USING(true) WITH CHECK(true) — anyone can read every invite, update peer's status, force a peer's call to accepted.	<i>Revert to AGORA_MIGRATION.sql policies (auth.uid() = caller/callee).</i>
Security	WalletScreen.js:40-75	"processPayment" runs entirely client-side. Any user can self-credit unlimited coins via dev console.	<i>Move to SECURITY DEFINER RPC; revoke client UPDATE on profiles.coins.</i>
HomeScreen	HomeScreen.js:392,1787,2451	Edit Post seeds modal from p.content, but posts use p.text. Opens empty, overwrites real text with empty string on Save.	<i>Read/write p.text consistently.</i>
Profile	ProfileScreen.js:130	Props destructure missing onViewUser + onSwitchTab → ReferenceError when tapping liker names or "View My Moment".	<i>Add to destructure, change calls to bare onViewUser(...) / onSwitchTab(...).</i>
Profile	ProfileScreen.js:431-447,978-988,1805-1812	saveEditProfile + Save Info + Expert App all rewrite bio JSON with only 4-5 keys → wipes cover_url, notif_prefs, sound_prefs, location, expert_request on every edit.	<i>Re-fetch bio, Object.assign(existing, {...}), then write.</i>
Profile	ProfileScreen.js:905-957	Help & Support "Send Message" button just toggles supportSent=true. No Supabase write, no email API. "Message Sent!" screen is a lie.	<i>Insert into support_tickets table OR post to a real endpoint.</i>
Search	SearchScreen.js:237-240	List-view Call button uses setActiveCall(e) directly, bypassing __ringInStartCall pipeline → callee never rings or gets push.	<i>Use window.__ringInStartCall(e) like the detail page does.</i>

HomeScreen + Feed

LOCATION	SEV	DESCRIPTION	FIX
<code>HomeScreen.js:1818</code>	MED	Wallet coin chip in header hardcoded "1,240"	Wire to live wallet query
<code>HomeScreen.js:1904-1909</code>	HIGH	Location filter chips have no onClick — purely decorative	Wire to filter or remove
<code>HomeScreen.js:2070</code>	MED	"See all" next to Online Now has no onClick	Navigate to Search tab
<code>HomeScreen.js</code> (none)	HIGH	No pull-to-refresh — feed only refetches on remount	Wire touch-y drag → re-run initial query
<code>HomeScreen.js:1479,2267</code>	HIGH	Audience selector writes to DB but feed never filters on read — followers/private posts visible to everyone	Apply <i>p.audience</i> filter or enforce via RLS
<code>HomeScreen.js:1142,2437</code>	MED	Infinite scroll is a manual "Load more" button; no IntersectionObserver	Auto-trigger <i>loadMoreFeed</i> at sentinel
<code>HomeScreen.js:1185-1210</code>	MED	Initial feed fetch refetches on every HomeScreen remount, ignoring cache	Skip fetch when cache <30s old
<code>HomeScreen.js:1492-1511</code>	MED	Per-follower notification settings query is N+1 (one-at-a-time loop)	Batch via <i>.in('follower_id', ids)</i>
<code>HomeScreen.js:29</code>	MED	EXPERTS array entirely hardcoded mock data; <i>online:true</i> is static	Fetch from profiles where <i>role=expert AND last_seen <5min</i>
<code>HomeScreen.js:166-171</code>	MED	Comments refetched on every comment-panel open — no TTL on cache	Skip if cached <30s
<code>HomeScreen.js:155,642</code>	LOW	<i>commentLoading</i> state defined but never set/read	Delete
<code>HomeScreen.js:1265</code>	LOW	Mock NOTIFS array still defined but never rendered (real notifs took over)	Delete
<code>HomeScreen.js</code> (multi)	LOW	8 <i>alert('Link copied!')</i> sites fire even when <i>clipboard.writeText</i> throws	Use toast, only on success
<code>HomeScreen.js:2423</code>	LOW	Typing-sound timer never cleared on unmount	Add <i>useEffect</i> cleanup

Moments

LOCATION	SEV	DESCRIPTION	FIX
Moments.js:330-336	HIGH	"Mute Status" writes to ringin_muted_moment_users but NOTHING reads it — muted users still appear in the strip	<i>Filter moments prop by this list at the call site</i>
Moments.js:292-320	HIGH	sendMomentToUser uses conversations schema (user1_id/user2_id) that doesn't match the real MessagesScreen flow — silently fails	<i>Match the existing convo-creation pattern</i>
Moments.js:265-282	MED	Share-sheet contacts fetched every time sheet opens, no dedup	<i>Cache contacts in module-level ref</i>
Moments.js:1335-1340	MED	"Save / open image" just opens URL in new tab — doesn't download as the label implies	<i>Use anchor with download attr, or relabel to "Open image"</i>
Moments.js:9-32	MED	Mock SAMPLE_SETS rendered for fake "expert" moments — users see fake "3 callers helped today" cards	<i>Hide moments for mock experts or label clearly</i>
Moments.js:170-174	MED	View upsert error silently swallowed — no warning if moment_views table missing	<i>Log RLS/missing-table errors once</i>
HomeScreen.js:750-776	MED	loadRealMoments() always fetches on currentUserId change with no TTL/dedup	<i>Reuse momentUsers shared cache</i>
HomeScreen.js:2037	MED	Mock expert moments injected with hasNew:true forever — never resets	<i>Track viewed state or remove "new" badge for mocks</i>
Moments.js:419-422	LOW	Liking shows "Liked ❤️" toast; UNliking shows nothing	<i>Add "Unliked" toast for symmetry</i>

Messages + Chat

LOCATION	SEV	DESCRIPTION	FIX
MessagesScreen.js:1607-1610	HIGH	Coin chip in Messages header hardcoded "1,240"	<i>Pipe live wallet balance</i>
MessagesScreen.js:1273-1274	HIGH	Pull-to-refresh indicator UI exists but NO touch handlers update its state — purely decorative	<i>Wire onTouchStart/Move/End or delete indicator</i>
MessagesScreen.js:1648,1762-1797	HIGH	Experts tab always shows 3 hardcoded mock conversations (e1/e2/e3). Call on these falls to local-only CallScreen (no Agora, no ring)	<i>Either populate from real experts in Supabase, or show empty state</i>
MessagesScreen.js:144-181,803	HIGH	Restrict toggle writes to restricted_users table but has ZERO downstream enforcement — messages from restricted users still play sound, increment badge, show typing	<i>Filter restricted set out of realtime push paths</i>
MessagesScreen.js:594-604	HIGH	Block-on-send compares conversation_id (uuid_uuid string) against ringin_blocked (list of UUIDs) — never matches. Blocked users still receive messages	<i>Use convo.otherId fallback chain; check blocked_users table too</i>
MessagesScreen.js:1799-1818	MED	Groups + Business tabs are permanent "coming soon" placeholders — implies parity with Friends	<i>Hide tabs until features exist, or behind feature flag</i>
MessagesScreen.js:1696-1759	MED	Muted conversations don't show a mute icon in the inbox list	<i>Render bell-with-slash when convId in mutedConvos</i>
MessagesScreen	MED	"Last seen" never surfaced in chat — heartbeat is running but unused	<i>When !isOnline, fetch profiles.last_seen_at and render</i>
MessagesScreen.js:254-271	MED	Reactions effect depends on [msgs.length] only — switching to a chat with same count briefly shows stale reactions	<i>Depend on [convId, msgs.length]; clear on convId change</i>
MessagesScreen.js:1107	MED	Photo optimistic message createObjectURL never revoked — small memory leak per photo	<i>Track URL + revoke when real msg arrives</i>
MessagesScreen.js:1330	LOW	No typing indicator surfaced in inbox row — only inside open chat	<i>Broadcast per-user, reflect in inbox preview</i>

Calls + Agora

LOCATION	SEV	DESCRIPTION	FIX
api/agora-token.js	CRIT	No auth, CORS *. Anyone mints publisher tokens for any channel + joins active calls + injects audio	<i>Verify Supabase JWT, validate against call_invites participants</i>
api/send-call-push.js	HIGH	No auth. Anyone fires FCM "Incoming Call from <arbitrary>" push to any user with FCM token	<i>Verify JWT; re-fetch invite server-side, derive callee/name from DB not body</i>
CallScreen.js:108-111	HIGH	PWA Speaker toggle only swaps Agora volume 50→100 — label says "loudspeaker" but acts like volume boost (native plugin not yet shipped)	<i>Hide on web or relabel "Boost volume"</i>
App.js:689-690	HIGH	CallScreen started with literal coins:1240, onCoinsChange:noop. Per-minute deduction is purely cosmetic — wallet never debited	<i>Wire to real wallet hook + RPC</i>
CallScreen.js:102,213-218,617	MED	audioDbg + RINGIN_BUILD label visible to end users in production	<i>Gate on NODE_ENV !== production</i>
CallScreen.js:312-317	MED	"No answer" auto-hangup uses functional setRingSecs to fire hangup — could double-fire in StrictMode/double-render	<i>Track ringSecs in ref, hangup outside setter</i>
CallScreen.js:404-428	MED	Only caller writes in-chat call log. If caller's PWA closes before insert, callee has no record	<i>Both sides write idempotently, dedupe on deterministic id</i>
IncomingCallModal.js:118-125	MED	Decline button has NO icon — empty red circle, looks broken	<i>Add phone-down / cross icon</i>
App.js:512	MED	window._ringInStartCall global — any third-party script in page can initiate calls from user's account	<i>Use React context instead</i>

Profile + Settings

LOCATION	SEV	DESCRIPTION	FIX
<code>ProfileScreen.js:130</code>	CRIT	Props missing onViewUser + onSwitchTab → ReferenceError on liker tap / "View My Moment"	Add to destructure
<code>ProfileScreen.js:431,978,1805</code>	CRIT	3 paths rewrite bio JSON without merge → wipes cover_url, notif_prefs, sound_prefs, location every save	Re-fetch + Object.assign + write
<code>ProfileScreen.js:905-957</code>	CRIT	Help & Support "Send Message" is purely UI — no DB write, no email — "Message Sent!" is a lie	Insert into support_tickets table
<code>ProfileScreen.js:1457</code>	HIGH	Blocked Users still uses localStorage('ringin_blocked'), not the server-backed blocks util. Cross-device sync broken	Use loadBlocks() + render via profiles fetch
<code>ProfileScreen.js:1457</code>	HIGH	Blocked Users list renders truncated UUIDs (meaningless to user)	Bulk-fetch profiles, show name + avatar
<code>ProfileScreen.js:1186</code>	HIGH	Email notifications toggle ONLY writes localStorage — never sent to Supabase, email service can't honor it	Mirror push-toggle persistence
<code>ProfileScreen.js:1365,1414,1436</code>	HIGH	Profile Visibility, Lock My Profile, Mute Activity Feed — all localStorage-only, no server-side effect	Persist to profiles columns + enforce in queries/RLS
<code>ProfileScreen.js:1221</code>	HIGH	Close Friends list renders truncated UUIDs instead of names + avatars	Bulk-fetch profiles for closeFriendsList
<code>ProfileScreen.js</code>	HIGH	No "Hide last seen" toggle — heartbeat runs but users can't opt out	Add toggle → profiles.last_seen_visible
<code>ProfileScreen.js:2333-2334</code>	MED	Composer Photo + GIF buttons alert("coming soon!") even though HomeScreen has working photo upload	Port the HomeScreen flow or remove
<code>ProfileScreen.js:2350,2353</code>	MED	Post 3-dot menu Edit + Turn-off-notifications are alert() stubs	Wire to existing flows or remove menu entries
<code>ProfileScreen.js:1826,2292</code>	MED	Stats tiles all hardcoded: 12 Calls, 1,240 Coins, 4.8★, 0 Reviews — pure fiction	Pull real counts from Supabase
<code>ProfileScreen.js:2283</code>	MED	"Member since April 2026" is hardcoded — doesn't reflect actual created_at	Read session.user.created_at
<code>ProfileScreen.js:1808</code>	MED	Expert App allows blank exp/rate; allows resubmit without warning	Validate non-empty + check pending status
<code>ProfileScreen.js:2462</code>	HIGH	Friends/Skills/Reviews tabs render hardcoded mock arrays — no real data ever appears	Pull from follows/skills/reviews tables or hide tabs
<code>ProfileScreen.js:1976</code>	MED	Rate the App is pure dummy — Submit just shows ✓; never logged or deep-linked to store	Wire to Play/App Store + Supabase log, or remove
<code>ProfileScreen.js:1880-1916</code>	MED	"Check for Updates" with auto-update ON doesn't actually auto-apply — contradicts toggle label	Auto-apply on manual check too, or relabel
<code>ProfileScreen.js:1304</code>	MED	Reset Password redirectTo hardcoded to web URL — Capacitor APK won't deep-link back	Detect Capacitor, use ringin:// scheme

SearchScreen

LOCATION	SEV	DESCRIPTION	FIX
SearchScreen.js:237	CRIT	List Call button bypasses <code>__ringInStartCall</code> → callee never rings	<i>Use the same fallback the detail page uses</i>
SearchScreen.js:9-16	HIGH	All 6 experts are hardcoded JS literals. Real expert applications never appear	<i>Fetch from profiles where <code>is_expert=true</code></i>
SearchScreen.js:228	MED	Every expert gets a "Verified" badge regardless of real verification	<i>Read <code>profiles.verified</code> column</i>
SearchScreen.js:156-159	MED	Coin tile "1,240" hardcoded (third copy of this issue)	<i>Single wallet hook</i>

OTA + Update flow

LOCATION	SEV	DESCRIPTION	FIX
otaUpdater.js:75-103	HIGH	<code>notifyAppReady</code> only called inside <code>checkOnly</code> (~4s after boot). If user is offline or manifest is slow, Capgo's failsafe rollback may fire before <code>notifyAppReady</code> → reverts to previous bundle	<i>Call <code>notifyAppReady</code> synchronously at <code>App.js</code> boot before any <code>setTimeout</code></i>
otaUpdater.js:25	HIGH	OTA bundle download has NO integrity verification — checksum/signature missing. If GitHub creds leak OR manifest is MITM'd OR malicious bundle uploaded, every device silently swaps to attacker JS on next 5-min poll	<i>Add <code>SHA-256 / Ed25519</code> signature to manifest; verify before <code>set()</code></i>
otaUpdater.js:132-156	MED	After <code>Capgo.next({id})</code> , reload via <code>setTimeout 120ms</code> — if <code>next()</code> is <code>async-pending</code> , reload may fire before bundle is staged → runs against OLD bundle	<i>await <code>staged-complete</code> event OR increase delay to 500ms</i>
otaUpdater.js:46-52	MED	Version tracking in <code>localStorage</code> only. If cleared, app forgets → "always offer update"	<i>Read from <code>Capgo.current()</code> with <code>localStorage</code> fallback</i>
UpdatePrompt.js:96-105	MED	Fake progress ticker has no <code>.then(done)</code> — if <code>__ringInDownloadOtaUpdate</code> resolves without reloading, bar stuck at 85% forever	<i>Add <code>.then(done)</code></i>
UpdatePrompt.js:139-214	MED	<code>style.opacity</code> ternary "finishing && !applying ? 1 : 1" both branches are 1 — dead code	<i>Remove ternary or set intended fade-in target</i>

Security findings (full)

ISSUE	SEV	FILE	DESCRIPTION
Committed admin secret	CRIT	python-service/.env:4	ADMIN_API_KEY=ringin-admin-secret-2026 publicly readable in repo
Anon key committed	HIGH	.env , python-service/.env	Supabase anon key in committed env files
Agora token endpoint unauth	CRIT	api/agora-token.js	No JWT check, CORS *, anyone joins any call
call_invites RLS disabled	CRIT	AGORA_RLS_LOOSEN.sql	USING(true) WITH CHECK(true) — anyone reads/writes any invite
send-call-push unauth	HIGH	api/send-call-push.js	Spoofable caller_name in lock-screen push
notifications spoofable	HIGH	SUPABASE_MIGRATIONS.sql:90	INSERT policy doesn't gate from_user_id or user_id — phishing/harassment
Wallet client-self-credit	CRIT	WalletScreen.js:40-75	Coins updatable from browser console
JSON-LD XSS	HIGH	api/preview.js:86	User-controlled post.text in <script> block without escape
Storage bucket overwrites	HIGH	SUPABASE_MIGRATIONS.sql:146	Any auth user can overwrite anyone's avatar/cover
OTA no signature	HIGH	otaUpdater.js:25	No checksum on bundle download — MITM / repo compromise risk
Hardcoded env fallbacks	MED	multiple	process.env.X '<real-prod-value>' defeats key rotation
Eruda debug in prod	MED	index.html:237	?debug=1 enables Eruda + persistent flag — phishing link → debug forever
last-seen view not security_barrier	MED	0006_last_seen.sql	View leak via query patterns; cross-user blocks not checked
Restrict comments client-only	MED	0003_restrict.sql	pending_approval enforced only in React — REST endpoint sees them all
messages/comments no RLS migration	HIGH	supabase/migrations/*	No RLS file for either table — either dashboard-only (unauditable) or wide open
Notification action consent	MED	App.js:101-108	Lock-screen "Accept" → mic publishes with no in-app confirm
profiles UPDATE unscoped	LOW	profiles policy	If UPDATE is auth.uid()=id, user can write coins/is_admin/etc
purge_deleted_accounts incomplete	LOW	0011_account_deletion.sql	auth.users row never deleted — fails GDPR Art. 17
is_admin on profiles	LOW	0002_reports.sql	User could self-promote if profiles UPDATE allows arbitrary cols
reports no rate-limit	LOW	0002_reports.sql	Malicious reporter can spam unbounded

Social-media comparison (what's missing vs Insta/FB/WhatsApp/LinkedIn/X)

Status / Moments

FEATURE	STATUS	RECOMMENDATION
Photo Moments + cube transition	✓ HAS	On par with Instagram. No change.
Video Moments	✗ MISSING	ADD ~2-3 days. MediaRecorder + 15s cap + Supabase upload.
Moment polls (binary tap)	✗ MISSING	ADD ~1 day. High engagement, one new table.
Text overlay / sticker / draw	✗ MISSING	DEFER. Heavy canvas editor (1-2 weeks).
Music overlay	⊘ SKIP	Licensing nightmare for small app, not core to thesis.
@mentions in reply	⚠ PARTIAL	UPGRADE ~1 day. Add picker.
"Seen by" viewer list	✓ HAS	Already wired (T2.5).
Highlights pinned to profile	✗ MISSING	ADD ~2 days. Promotes expert credibility.

Chat

FEATURE	STATUS	RECOMMENDATION
1:1 chat, reactions, unsend, mute, block	✓ HAS	Solid baseline.
Group chat	✗ MISSING	ADD ~1 week. Schema refactor needed. Highest-value missing feature.
Voice notes	✗ MISSING	ADD ~2 days. Mobile expectation. MediaRecorder → bucket → audio bubble.
Reply-to / quote message	✗ MISSING	ADD ~1 day. reply_to_message_id column.
Forward message	✗ MISSING	ADD ~1 day.
Message search	✗ MISSING	ADD ~1 day. Extend existing post FTS to messages.
Pinned messages	✗ MISSING	~1 day. Low urgency.
Disappearing messages	✗ MISSING	DEFER ~2 days. Privacy story is secondary to growth.
GIF picker (Tenor)	✗ MISSING	ADD ~1 day. Trivial API. Huge perceived polish.

Calls

FEATURE	STATUS	RECOMMENDATION
1:1 voice with Agora + push + native audio	✓ HAS	Excellent foundation.
Video calls	✗ MISSING	ADD ~3-4 days. Agora SDK already loaded; just UI. Transforms RingIn into the go-to expert face-time app.
Group calls	✗ MISSING	DEFER until video 1:1 ships.
Screen share	✗ MISSING	ADD ~1-2 days. getDisplayMedia + Agora track. Killer for tech/legal experts.
Call recording (with consent)	✗ MISSING	ADD ~3 days. Major trust signal for paying users.
Low-bandwidth audio mode	✗ MISSING	~2 hours. Agora.setAudioProfile.

Profile / Identity

FEATURE	STATUS	RECOMMENDATION
Verified badge	⚠ PARTIAL	UPGRADE ~1 day. Badge visual exists in SearchScreen but no real flow. Major trust signal.
Profile QR code	✗ MISSING	ADD ~3 hours. Big in-person growth boost.
Multi-link bio (Linktree)	✗ MISSING	ADD ~half day. Critical for experts.

Discovery

FEATURE	STATUS	RECOMMENDATION
Explore / suggested feed	✗ MISSING	ADD ~2 days. Top-engagement posts last 24h grid.
"Who to follow"	⚠ PARTIAL	UPGRADE ~half day. mIService exists but not surfaced.

Monetization

FEATURE	STATUS	RECOMMENDATION
Coin tipping on posts/Moments	✗ MISSING	ADD ~2 days. Strong fit — wallet rails exist. Heart-burst UI on tap.
Creator subscriptions	✗ MISSING	DEFER. Worth it at 20+ active experts.

Safety + Growth

FEATURE	STATUS	RECOMMENDATION
Admin moderation dashboard	✗ MISSING	ADD ~2 days. Reports are saved but no admin tool. Legal cover.
Two-factor auth (TOTP)	✗ MISSING	ADD ~1 day. Supabase Auth native support.
Public post/expert pages	✗ MISSING	CRITICAL ~2 days. Without this, all shares break.
Invite a friend (bonus coins)	✗ MISSING	ADD ~1-2 days. Cheapest growth channel.
Deep-link routing	⚠ PARTIAL	UPGRADE ~half day. ?tab= works but no ?post= or ?expert=.

Top 5 highest-ROI additions

1. **Video calls** (~3-4 days) — Agora already wired, mostly UI. Transforms RingIn from "voice consultation" to "real expert face-time" — competes with Zoom/FaceTime.
2. **Public post pages + share-back loop** (~2 days) — /post/:id SSR route on Vercel + working share + invite-friend bonus. Biggest growth blocker right now.
3. **Voice notes in chat** (~2 days) — Universal mobile expectation. Missing it makes RingIn feel incomplete next to WhatsApp.
4. **Coin tipping on posts / Moments** (~2 days) — Wallet + billing rails exist. Monetizes free creators. Heart-burst viral moment.
5. **Verified badge + admin moderation dashboard** (~3 days combined) — Badge UI is fake right now. Real verification + /admin page gives trust posture for payments to scale.

What works well (so you know the audit was thorough)

HomeScreen + Moments

- **AvatarRing component** — clean conditional wrapper, gracefully degrades
- **ReportModal** — real Supabase insert with localStorage queue fallback
- **Optimistic-with-snapshot-rollback** on every mutation (toggleLike, submitComment, deletePost, saveEditPost)
- **Notification batching** — collapses same-type same-post within 30-min window
- **Feed diversity cap** — breaks up consecutive same-author posts
- **Moments cube transition** — single per-frame transform on cube wrapper, GPU-composited
- **MomentComposer pinch-zoom** — direct-DOM transform writes via ref, 60fps
- **Android back-button handling** — popstate guard via __ringinMomentDragTime

Messages + Calls

- **Realtime subscription hygiene** — every sb.channel has a matching removeChannel cleanup
- **iOS Safari user-activation** — mic track created before token roundtrip preserves tap activation
- **Token pre-fetch on incoming ring** — cuts ~200-500ms accept latency
- **Conv list caching** — localStorage with stale detection
- **Race-condition fix for outgoing channel** — pre-generates invite UUID client-side, doc'd clearly
- **CallScreen unmount cleanup** — wake lock, listener (refed not lambda), timeouts, audioSession restoration
- **setMuted vs setEnabled** — peers don't see user-unpublished which would have ended the call
- **FCM token cleanup on invalid-token** — blanks bad tokens automatically

Profile + Settings

- **Sound & Haptics screen** — toggles, sliders all persist correctly
- **Hide Like Counts** — updates instantly across tabs via storage event
- **Close Friends add/remove** — server-backed, optimistic, debounced FTS
- **Notification toggles** → **push types** — write to localStorage + bio + notification_prefs table
- **Password Change** — verifies current password via re-signIn before update
- **Delete Account flow** — confirm + RPC + signOut + 30-day cooling-off copy
- **Download My Data** — real JSON export of posts + comments via Blob download
- **Activity Log** — real Supabase fetches + realtime channel with cleanup

Security (secure-by-default)

- **Agora App Certificate kept server-side** — only App ID exposed (correct)
- **Firebase Admin lazily initialized** — service-account never echoed to client
- **Most migrations 0001-0015** correctly enable RLS + gate on auth.uid()
- **purge_deleted_accounts, refresh_trending_tags** — SECURITY DEFINER with revoke from public/authenticated
- **Service worker** bypasses caching for Supabase/Agora/Firebase/api — protects auth and prevents poisoning
- **capacitor.config.json** — cleartext:false, autoUpdate:false (user approves every OTA)
- **vercel.json** — X-Content-Type-Options: nosniff + Referrer-Policy global headers
- **Expand-contract migration pattern** documented in CLAUDE.md is properly followed (try/catch around new column reads)